

Plan de sécurité et de conformité

Stripe traite des milliards de transactions financières par an, les données manipulées sont donc particulièrement sensibles. Ces données incluent également des données personnelles et des informations commerciales confidentielles. Ce document décrit le cadre de sécurité mis en place pour protéger ces données et garantir la conformité réglementaire.

1. Chiffrement des données

Le chiffrement est à distinguer selon deux types de données : celles qui sont en transit et celles qui sont stockées.

En ce qui concerne les données qui circulent, toutes les communications entre les systèmes doivent utiliser le protocole SSL/TLS. Les données sont donc chiffrées pendant leur transport entre PostgreSQL, Kafka, MongoDB et Snowflake. Les communications entre Stripe et ses clients, via leur navigateur et leur application mobile, doivent utiliser le protocole HTTPS. Celui-ci garantit que personne ne peut intercepter les données de paiement. Enfin, les données des cartes bancaires doivent transiter sous forme de token chiffré, jamais en clair sur le réseau.

Pour ce qui est des données stockées, toutes les bases de données doivent utiliser le Transparent Data Encryption. Grâce à celui-ci, les fichiers stockés sur disques durs sont automatiquement chiffrés. Les numéros des cartes bancaires ne doivent jamais être stockés en clair, et doivent donc être tokenisés. Les clés de chiffrement doivent être gérées par Key Management Service. Elles seront alors enregistrées à un endroit différent des données afin d'éviter qu'un accès aux données donne un accès aux clés. Les backups doivent être également chiffrés avant d'être stockés sur S3.

2. Contrôle d'accès via RBAC

Le Role-Based Access Control doit être mis en place sur tous les systèmes. Ainsi, chaque utilisateur a uniquement les permissions qui incombent à leur rôle. Les rôles définis sont : "Admin" a un accès total à tous les systèmes. "Data Engineer" a un accès en lecture et écriture sur PostgreSQL, Snowflake et MongoDB. "Data Analyst" a un accès de lecture seule sur Snowflake ANALYTICS. "Developer" a un accès de lecture et d'écriture sur les tables OLTP uniquement. "Compliance Officer" a un accès en lecture seule sur "fact_compliance" et les logs audit. Le principe du moindre privilège est appliqué, cela signifie que personne n'a plus d'accès que ce dont il a besoin. L'authentification MFA, pour Multi-Factor Authentication est obligatoire pour tous les accès aux bases de données. Les accès sont revus régulièrement, un employé qui change de poste perd ses anciens accès automatiquement. Aussi, les credentials, comme les mots de passe et les clés API, sont stockés dans un coffre-fort sécurisé, comme HashiCorp Vault.

3. Journalisation des audits

Tous les accès aux données sensibles doivent être enregistrés automatiquement dans "fact_compliance" au sein de l'OLAP. Chaque log d'audit contient : la personne qui a accédé aux données avec "user_id". Quand elle a accédé aux données avec "timestamp". Qu'est-ce qu'elle a effectué avec "table" et "action". Depuis où elle l'a fait avec "ip_address". Ces logs sont immuables, personne ne peut les modifier et les supprimer. Ils sont enregistrés sur PostgreSQL et doivent être conservés au minimum un an, pour répondre aux exigences réglementaires. Les logs doivent être

analysés en temps réel pour détecter les comportements suspects, comme par exemple un utilisateur qui accède à des milliers de données clients en quelques minutes.

4. Conformité RGPD

Le Règlement Général sur la Protection des Données s'applique à toutes les données des clients européens de Stripe. Elle implique le droit à l'oubli : un client peut demander la suppression de ses données. Une cascade de suppression doit alors être déclenchée automatiquement dans les trois systèmes via le CDC. Le consentement doit être explicite. Stripe doit demander et enregistrer le consentement de chacun de ses clients européens concernant l'utilisation de ses données. Seules les données strictement nécessaires doivent être collectées. On ne stocke par exemple pas le numéro complet d'une carte de paiement, seulement ses quatre derniers chiffres. La portabilité des données doit être assurée. Un client européen peut donc demander l'exportation de toutes ses données dans un format lisible par lui. En cas de fuite des données, Stripe doit notifier les autorités dans les soixante-douze heures maximum. Les données de ses clients européens doivent être stockées dans des datacenters du même continent. Un Data Protection Officer doit être assigné pour superviser la conformité RGPD.

5. Conformité PCI-DSS

En tant que société qui traite les paiements par carte bancaire, Stripe doit se conformer au standard de sécurité PCI-DSS, pour Payment Card Industry Data Security Standard. Les numéros des cartes ne doivent jamais être stockés en clair, mais remplacés par des tokens. Les systèmes qui traitent les données des cartes sont isolés dans une zone réseau sécurisée. Les systèmes doivent être scannés régulièrement pour détecter des failles de sécurité. Des tests d'intrusion doivent être effectués, au moins une fois par an pour identifier les points faibles. Tous les systèmes sont mis à jour régulièrement pour corriger les vulnérabilités connues. Les datacenters qui hébergent les données de carte sont sécurisés physiquement. Étant donné que Stripe dépasse les six millions de transactions par an, l'entreprise doit être certifiée PCI-DSS niveau un, qui est le niveau le plus élevé.

6. Reporting et monitoring automatisés

Un monitoring en temps réel doit être mis en place en matière de sécurité. Le système doit surveiller en permanence les comportements suspects. Ces comportements concernent l'accès inhabituel aux données sensibles, les tentatives de connexion échouées répétées, les volumes de transactions anormaux et les accès depuis des pays inhabituels. Les alertes doivent être envoyées immédiatement par email et Slack à l'équipe sécurité.

Les rapports de conformité doivent être également automatisés. Ils sont générés automatiquement depuis "fact_compliance" dans l'OLAP. Il doit en exister plusieurs types. Les rapports quotidiens listent les accès aux données sensibles. Les rapports hebdomadaires résument les incidents de sécurité. Les rapports mensuels font état de la conformité aux RGPD et PCI-DSS. En ce qui concerne les outils utilisés, Snowflake Access History surveille tous les accès aux données dans Snowflake. MongoDB Audit Log enregistre tous les accès dans MongoDB. PostgreSQL logs enregistre toutes les opérations sur l'OLTP et Airflow monitoring surveille l'exécution des pipelines de données.

Ainsi, le chiffrement protège les données contre les accès non autorisés. Le RBAC garantit que chaque utilisateur accède uniquement aux données qui lui sont nécessaires. La journalisation des audits permet de tracer chaque accès aux données sensibles. La conformité RGPD et PCI-DSS protège Stripe contre les sanctions réglementaires et le monitoring automatisé permet de détecter rapidement les incidents de sécurité. L'ensemble de ces mesures permet à Stripe de répondre aux exigences réglementaires les plus strictes.